

Cybersecurity Awareness

TOPIC LEARNING OBJECTIVES

Upon successful completion of this topic, the student will be able to:

1. Recognize the importance of cybersecurity in the DoW, including its history and evolution.
2. Recognize the increasing sophistication of the threat to DoW cybersecurity.
3. Explain the consequences of not protecting DoW systems from cyber attacks.
4. Recognize key players and policy in cybersecurity including the intelligence community.
5. Recognize the critical processes that make and maintain secure systems, to include Risk Management Framework (RMF).
6. Explain how cybersecurity is integrated into every aspect of the acquisition program life-cycle, including both sides of the Systems Engineering "V" and the program protection plan.
7. Recognize that everyone, including EDOs, have a role in cybersecurity.

STUDENT PREPARATION

Student Support Material

1. 1. WarU Cybersecurity Video https://media.WarU.edu/media/1_azceykk4
2. DoN CIO Zero Trust https://www.dau.edu/sites/default/files/2025-03/DAU%20Transforming%20Cybersecurity%20-%20DON%20ZT%20Blueprint%20Update-1.pdf
3. Cyber Security Risk Management Construct (CSRMC) https://www.war.gov/News/Publications/Search/cyber/

Primary References

1. DoW Program Manager's Guidebook for Integrating the Cybersecurity Risk Management Framework (RMF) into the System Acquisition Lifecycle

Additional References

1. WarU ISA 1011 Information Systems Acquisition
2. WarU ISA 220 Risk Management Framework (RMF) for the Practitioner
3. WarU CLE 074

Overview

- The Basics
  - What is cybersecurity
  - Importance of cybersecurity (real world examples of threat environment)
- DoW's (and the Navy's) Approach
  - Cyber-related organizations
  - Cybersecurity Risk Management Framework and the Acquisition Process
  - DON CIO Zero Trust
- Cybersecurity is everyone's role
  - Cyber hygiene
  - Role of EDOs

What is Cybersecurity? (DoDI 8500.01)

- Prevention of damage to, protection of, and restoration of computers, electronic communication systems, electronic communication services, wire communication, and electronic communication, including information contained therein, to ensure its:
  - Confidentiality
    - Is my data safe against disclosure to unauthorized entities?
  - Integrity
    - Is my data safe against modification and destruction?
  - Availability
    - Can I access my data/network resources as required and in a timely manner?
  - Non-Repudiation
    - Ensures that no parties can deny that it sent or received a message via encryption and/or digital signatures or approved some information
  - Authentication
    - The process of verifying whether someone is, in fact, who it is declared to be

What is Cybersecurity? (DoDI 8500.01)

- A loss of ***confidentiality*** is the unauthorized disclosure of information
  - Theft of Personal Identifiable Information (PII) - Social Security Number (SSN), etc.
  - Classified information exfiltration from Secret Internet Protocol Router Network (SIPRNet)

- A loss of ***integrity*** is the unauthorized modification or destruction of information
  - Unauthorized modification of Global Positioning System (GPS) navigation information
  - Unauthorized destruction of PII on a Defense Business System (DBS)

- A loss of ***availability*** is the disruption of access to or use of information or an information system
  - Denial of Service (DoS) attack on Nuclear Command, Control and Communications (NC3) network
  - DoS attack on logistics parts ordering system
  - DoS attack on unmanned system command and control (C2) link

Driving Emphasis for Cybersecurity

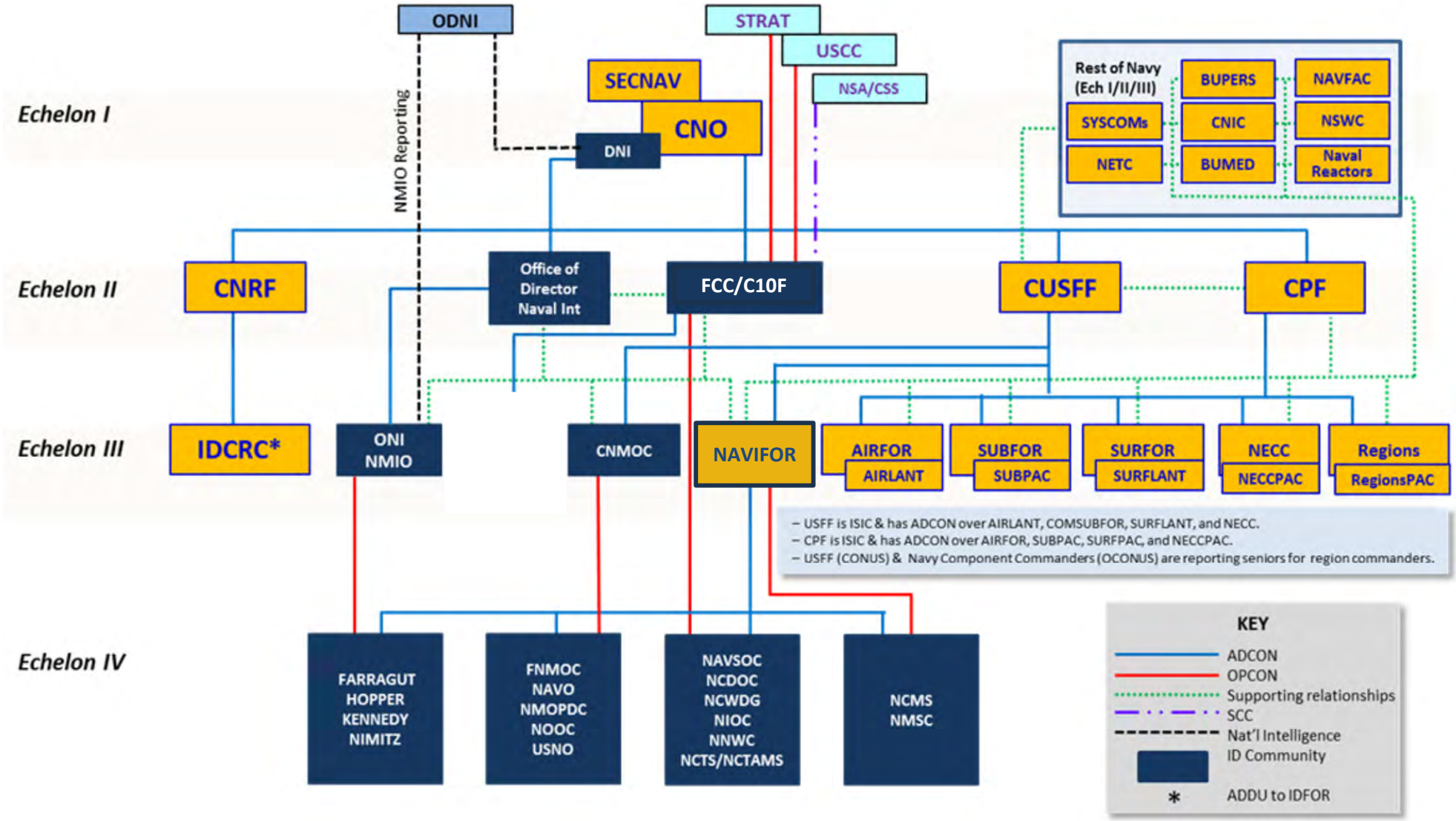
- **1998** – SOLAR SUNRISE Network intrusion on DoD networks
- **2006** – State Department networks hacked by unknown foreign intruders
- **2008** – Agent.btz: USB intrusion on DoD computers
- **2008** – Supply chain attack on credit card readers made in China
- **2009** – Conficker worm infects military databases and grounds French naval aircraft
- **2013** – Operation ROLLING TIDE in response to adversary intrusion on Navy networks
- **2015** – Office of Personnel Management (OPM) data breach
- **2017** – Equifax data breach
- **2018-2020** - Ransomware attacks on U.S. cities & hospitals



Overview

- The Basics
  - What is cybersecurity
  - Importance of cybersecurity (real world examples of threat environment)
- DoW's (and the Navy's) Approach
  - Cyber-related organizations
  - Cybersecurity Risk Management Framework and the Acquisition Process
  - DON CIO Zero Trust
- Cybersecurity is everyone's role
  - Cyber hygiene
  - Role of EDOs

Cyber C2 Organization



Cyber-related Organizations

- DoN Chief Information Officer (CIO)
  - Policy and guidance
    - Evaluating and improving security of IT systems
    - Network architectures and interoperability
- US Cyber Command (USCYBERCOM)
  - Combatant Commander responsible for global cyber operations
  - Sets policy for entire DoW enterprise
- Fleet Cyber Command/U.S. 10th Fleet
  - Responsible for operations, maintenance, and defense of Navy networks (OPCON)
  - Navy Component Commander to USCYBERCOM
    - Sets cyber policy for the Navy, at the direction of USCYBERCOM
- Navy Cyber Defense Operations Command (NCDOC)
  - Cyber Security Service Providers (CSSP)
  - Actively defends Navy networks and performs incident response and forensics
  - Threat focused

Cyber-related Organizations

- Naval Network Warfare Command (NAVNETWARCOM)
  - Tactical level command and control of Navy networks
  - Directs, operates, maintains, and secures Navy communications and network systems
  - Focus on security
- Naval Information Forces Command (NAVIFOR)
  - ***Cyber Type Commander (TYCOM)***
  - Organizes, mans, trains, and equips cybersecurity workforce
    - Cybersecurity Division Officer billet added to some ships
    - Training/assist visits for cybersecurity readiness inspections
- Naval Information Warfare Systems Command (NAVWAR)
  - ***Navy Cybersecurity Technical Authority (CS TA)***
  - Establish, monitor, and approve technical standards, tools, and processes
  - Responsible for cybersecurity architecture, specs, standards, and protocols
  - Warrant cybersecurity technical warrant holders within SYSCOMs
- Other Systems Commands
  - Design secure systems in alignment with CS TA standards

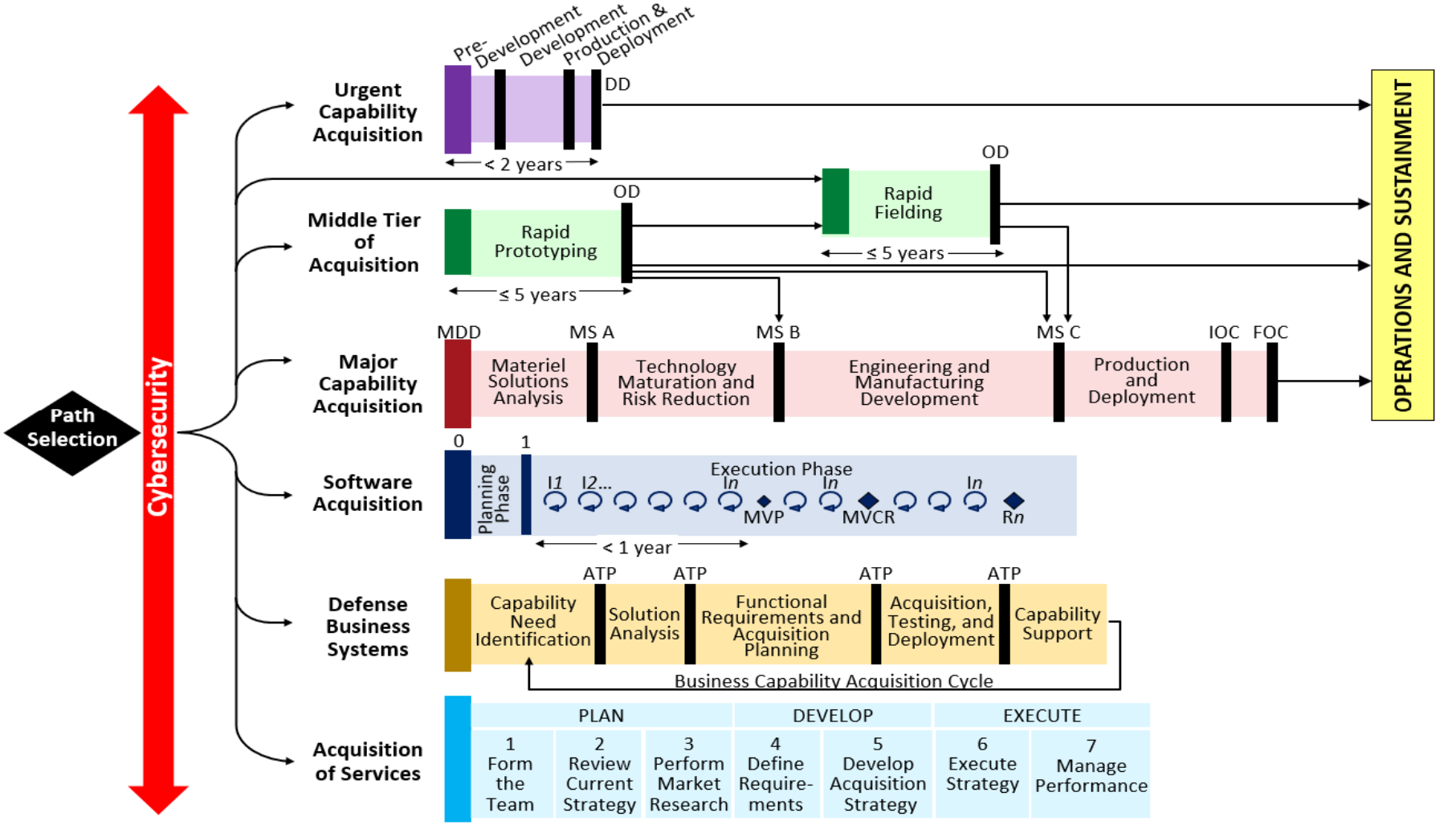
Intelligence Community

- PMs must use cyber threat information produced by the Intelligence Community (IC) in the development of their cyber security strategy assessment of risks
- Intelligence Community products that support acquisition programs include:
  - Validated Online Life-cycle Threat (VOLT) reports
    - The primary threat document supporting a specific defense program
    - Includes all threat modules relevant to the supported program
  - Capstone Threat Assessments (CTA): Forecast threat capabilities for specific warfare areas
  - Technology targeting risk assessments

Listing of Capstone Threat Assessments

Warfare Area	Primary Production Office or Center
Air Warfare	National Air and Space Intelligence Center (NASIC)
Chemical, Biological and Radiological Defense	Defense Intelligence Agency (DIA)
Information Operations	DIA/Joint Information Operations Threat Working Group
Land Warfare	National Ground Intelligence Center (NGIC)
Missile Defense	Defense Intelligence Agency (DIA)
Naval Warfare	Office of Naval Intelligence (ONI)
Space Warfare	National Air and Space Intelligence Center (NASIC)

Cybersecurity and Adaptive Acquisition Framework



Cybersecurity Strategy crosses all pathways within the Adaptive Acquisition Framework

Cybersecurity in the Acquisition Process

- The PM is responsible for meeting cybersecurity requirements throughout the life-cycle of the program

- A program's cybersecurity strategy annex must be documented within the Program Protection Plan (PPP)
  - The cybersecurity annex will document how the system will operate in a cyber-contested environment as well as the consequences of a cybersecurity breach and related concerns

- The Cybersecurity Risk Management Framework (RMF) is required for all acquisitions containing Information Technology

Cybersecurity Strategy is part of the Program Protection Plan and is a statutory requirement starting at M/S A and updated at each milestone

Risk Management Framework

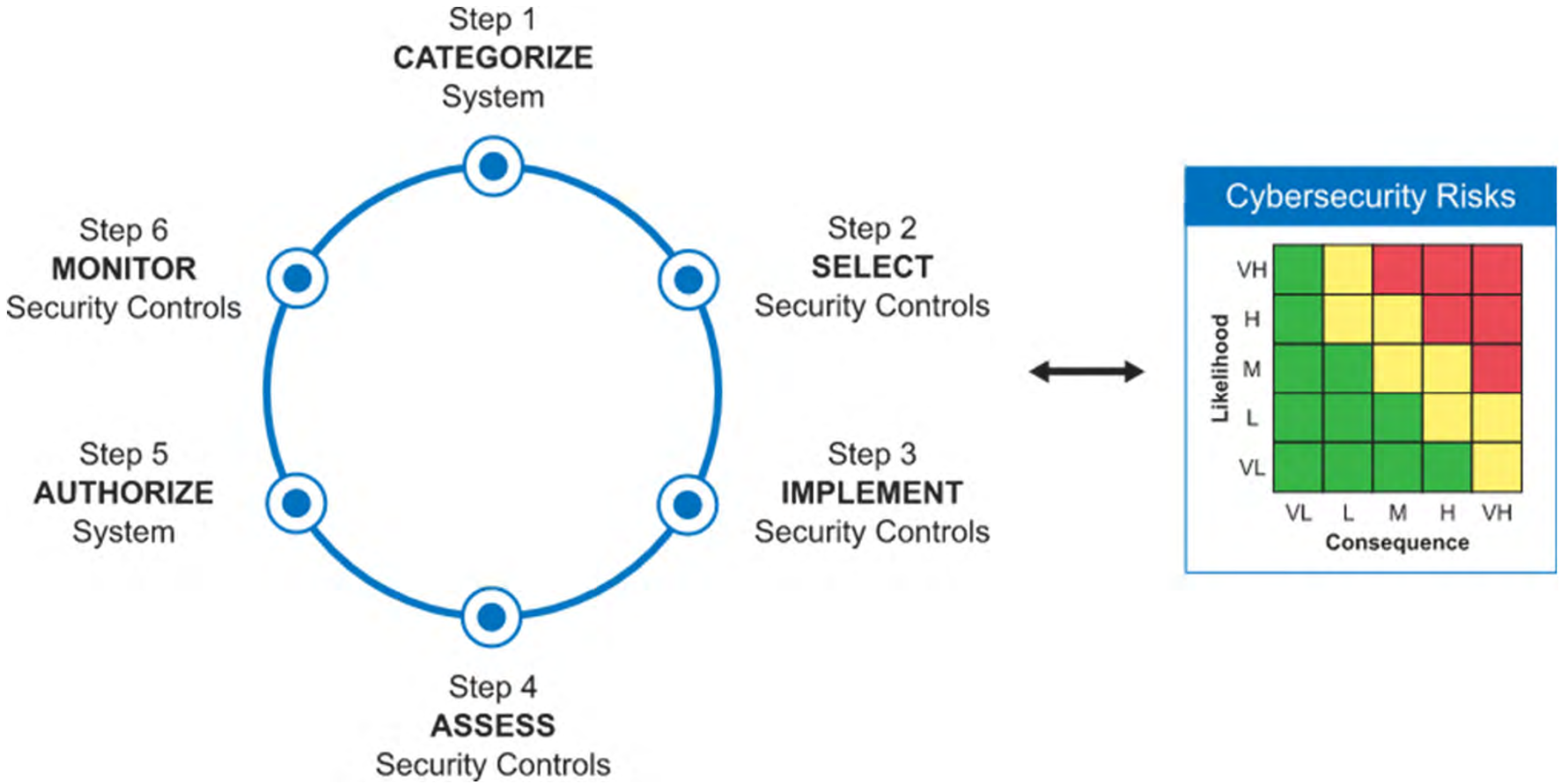
- What is RMF?
  - A process that integrates security and risk management activities into the acquisition life-cycle
  - A 6-step process that emphasizes continuous monitoring and timely correction of deficiencies
  - Applicable to all Information System (IS) and Platform Information Technology (PIT) systems as well as DoW partnered systems
- Goals of RMF
  - Perform risk assessment throughout the acquisition life-cycle
  - ***Cybersecurity "baked in" vs "bolted on"***
  - Improve information security
  - Improve understanding of risks to Navy systems and missions

RMF is executed throughout the acquisition life-cycle

Importance of Assessing Risk

- RMF requires cybersecurity risk assessments and management
  - Risk assessments help decision-makers determine:
    - To what degree can threat actors impact Navy systems and missions via cyber-attack?
    - Where can mitigations most effectively and efficiently be employed?
    - Which risks should the Navy prioritize, accept, or actively mitigate?
- Risk assessments allow information system owners to identify high-level risks
- Information System Owners may tailor security controls, but the risk associated with not implementing a control must be assessed and recorded

Risk Management Framework



Step 1: Categorize the System

- Categorize the system and the information processed, stored, and transmitted by that system based on a potential impact
  - Identify all types of information:
    - e.g., privacy, medical, proprietary, financial, investigative, contractor-sensitive, security management
    - Can be defined by an organization or, in some instances, by a public law, executive order, directive, policy, or regulation
  - Select Security Objective: Confidentiality, Integrity, Availability
  - Determine Level of impact (X): Low, moderate, or high
  - Security Category = (Confidentiality, X), (Integrity, X), (Availability, X)
    - Example: Security Control Health Information= (Confidentiality, High), (Integrity, High), (Availability, Low)
  - Document the categorization within the program protection plan
- Initiate the Security Plan
- Register system with DoW Component Cybersecurity Program
- Assign qualified personnel to RMF roles

Step 2: Select Security Controls

- Select security controls based on categorization of the system
  - To meet security requirements as defined by DoW baseline configuration standards
  - To ensure the integrity, confidentiality, and availability of the information and information system in accordance with the organization's protection strategy
  - Security controls are selected according to CNSSI 1253 for all DoW systems, including National Security Systems (NSS)
  - Can tailor and supplement security controls to address the risk associated with the specific system
- Develop system-level continuous monitoring strategy
- Review and approve the Security Plan and continuous monitoring strategy

ID	TITLE	Confidentiality			Integrity			Availability		
		L	M	H	L	M	H	L	M	H
AC-1	Access Control Policy and Procedures	X	X	X	X	X	X	X	X	X
AC-2	Account Management	X	X	X	X	X	X			
AC-2(1)	Account Management | Automated System Account Management		X	X		X	X			
AC-2(2)	Account Management | Removal of Temporary / Emergency Accounts		X	X		X	X			

Step 3: Implement Security
Step 4: Assess Security Control

- Implement security controls
  - Implement control solutions consistent with DoW Component Cybersecurity architectures
    - Translate security controls into systems specification
    - Integrate specifications into the system design
  - Document security control implementation in the Security Plan

- Assess security controls
  - Develop and approve Security Assessment Plan
  - Assess security controls
    - Were the system controls properly implemented?
  - Security Control Assessor (SCA) prepares Security Assessment Report (SAR)
    - SCA makes recommendation for cybersecurity risk acceptance or denial
  - Conduct initial remediation actions

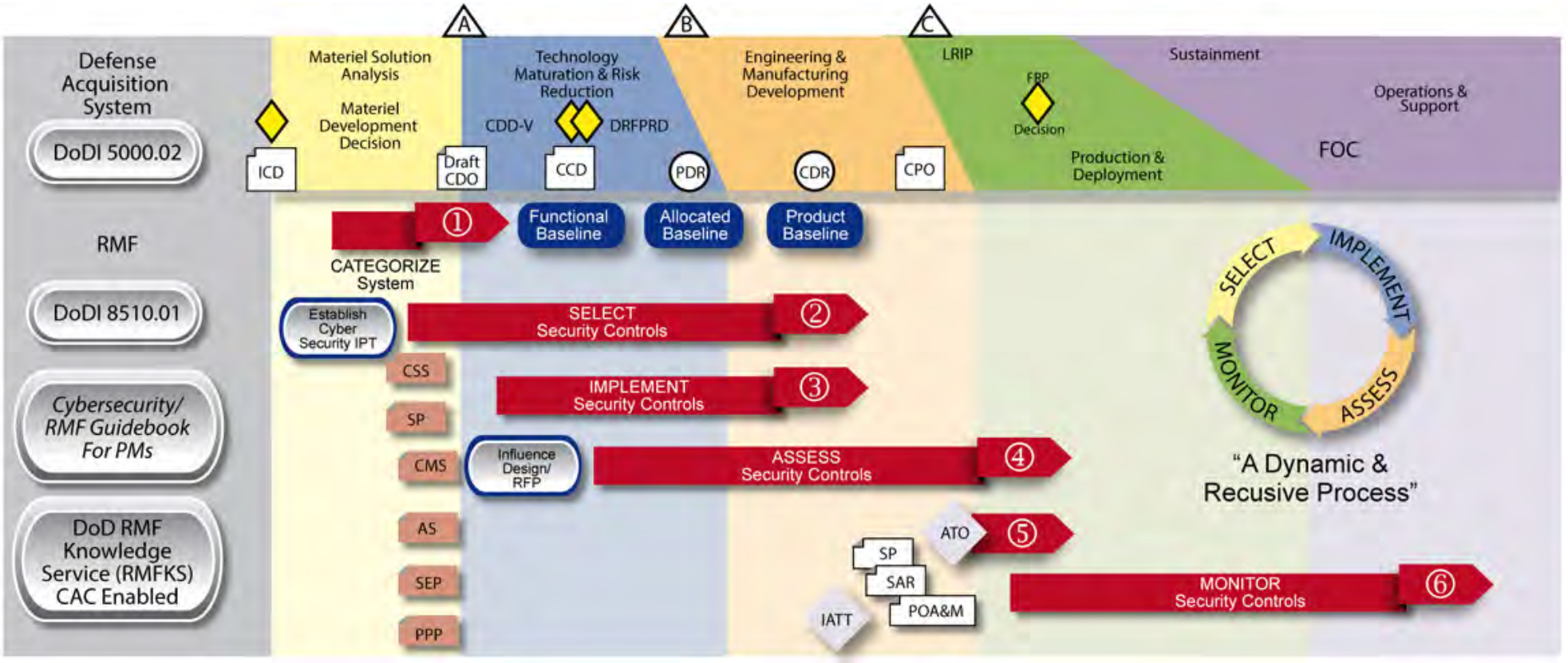
Step 5: Authorize System

- Authorize system
  - Prepare Plan of Action and Milestones (POA&M) based on vulnerabilities identified in Step 4
    - POA&M reflects organizational priorities for addressing any remaining weaknesses and deficiencies in an information system and its environment of operation
  - Submit Security Authorization Package to the Authorizing Official (AO). The Authorization Package contains:
    - Security Plan
    - Security Assessment Report
    - POA&M
  - AO conducts final Risk Determination and Risk Assessment
  - AO makes authorization decision
    - A DoW authorization decision is expressed as an Authorization to Operate (ATO), an Interim Authorization to Test (IATT), or a Denial of Authorization to Operate (DATO)

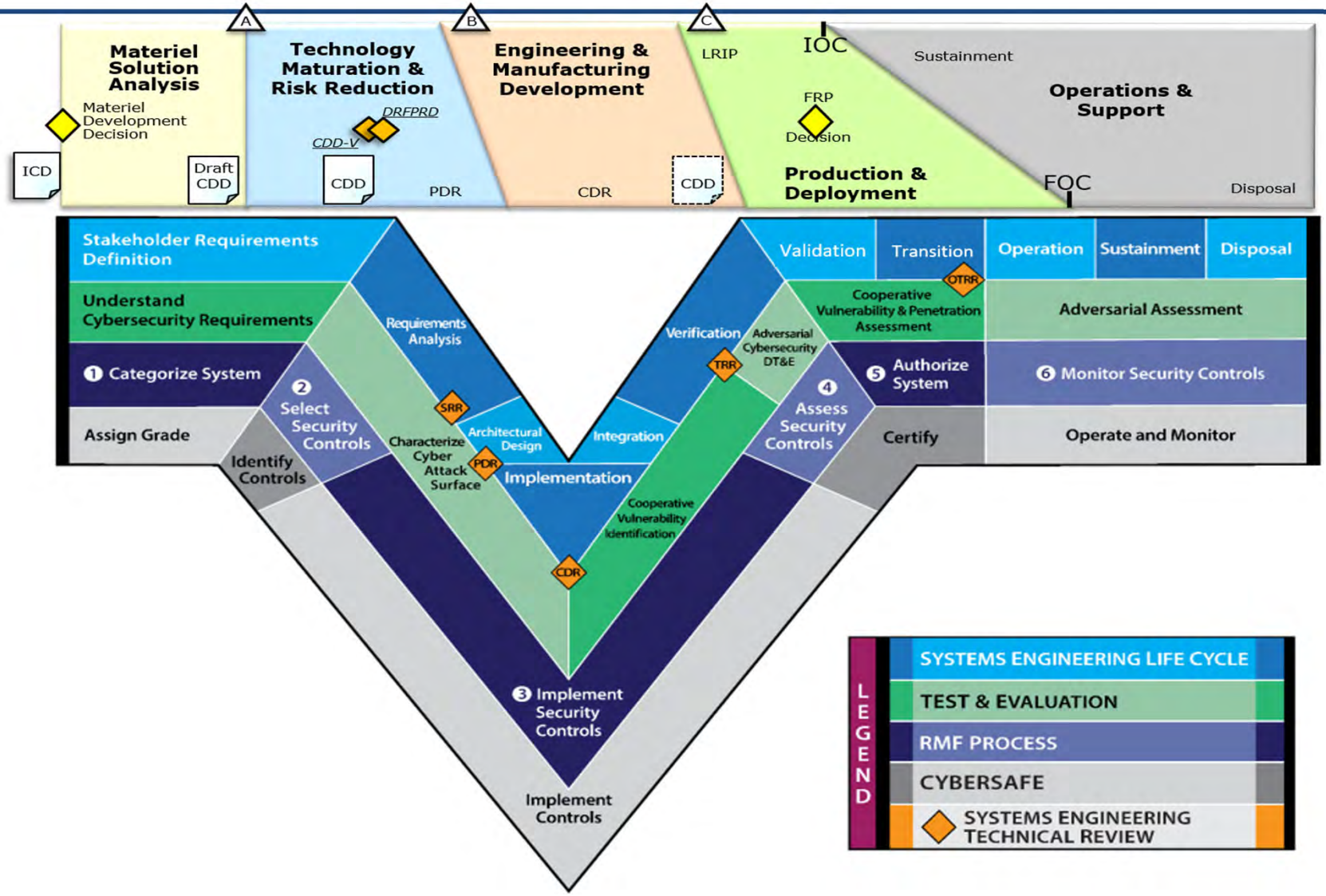
Step 6: Monitor Security Controls

- Monitor security controls
  - Determine impact of changes to the system and environment
  - Assess selected controls annually
  - Conduct needed remediation
  - Update security plan, SAR, and POA&M
  - Report security status to AO
  - AO reviews reported status
  - Implement system decommissioning strategy

RMF across Acquisition Lifecycle



RMF Across the Life-cycle



Overview

- The Basics
  - What is cybersecurity
  - Importance of cybersecurity (real world examples of threat environment)
- DoW's (and the Navy's) Approach
  - Cyber-related organizations
  - Cybersecurity Risk Management Framework and the Acquisition Process
  - DON CIO Zero Trust
- Cybersecurity is everyone's role
  - Cyber hygiene
  - Role of EDOs

Cyber Hygiene

- Install and maintain firewalls
  - Review firewall logs for signs of intrusion
- Perform routine scans of network systems, looking for malware or other unauthorized software
- Perform routine scans of systems looking for known vulnerabilities
  - Take timely actions to eliminate or mitigate those vulnerabilities
- Whitelisting
  - Software that will only allow authorized programs to run
  - Prevents programs that are downloaded inadvertently or maliciously from running
- Ensuring all network hardware uses a common and approved baseline image
  - Don't make changes that contradict a system's configuration management policy and procedures

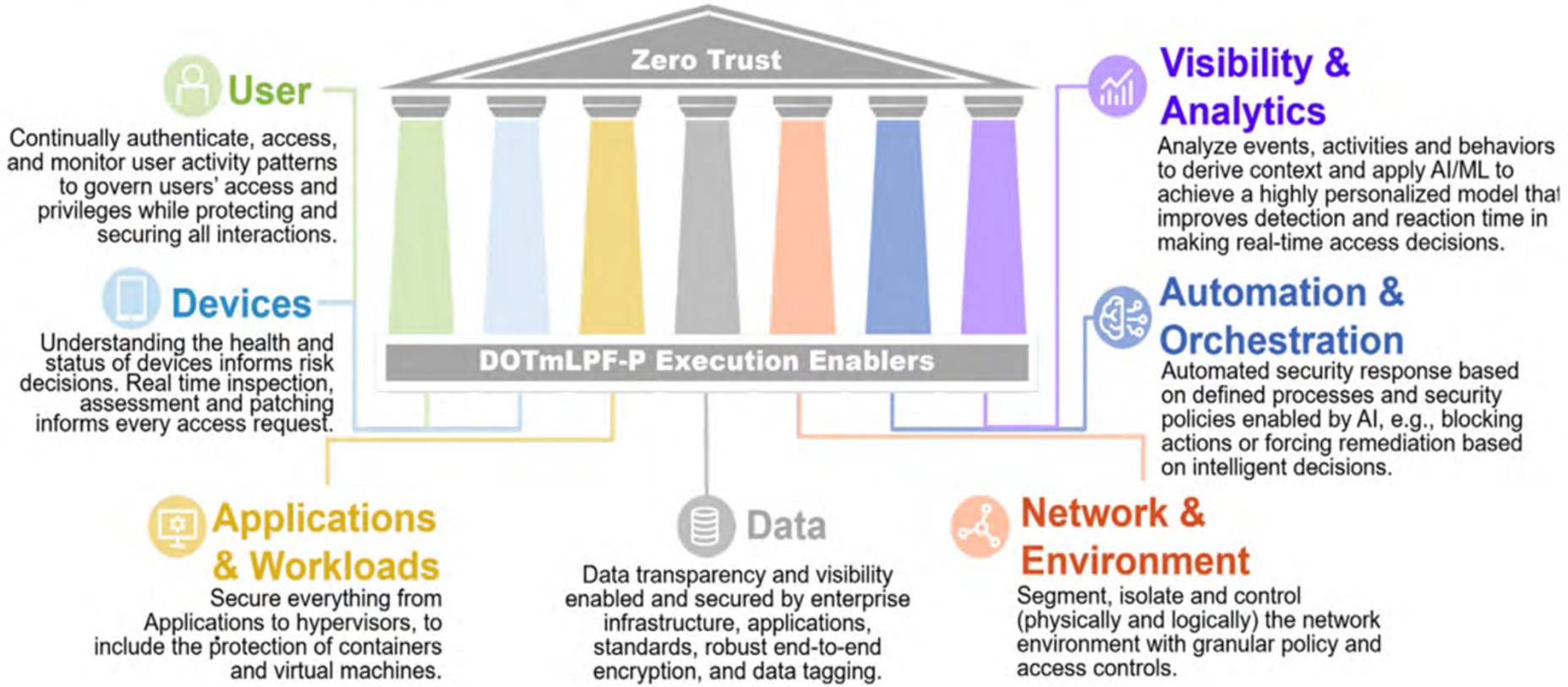
EDO's Role in Cybersecurity

- Program Managers are responsible for the Cybersecurity of their programs, systems, and information
  - Cybersecurity must be part of every stage in the program life-cycle
- EDOs must be knowledgeable leaders
  - Cybersecurity is a critical aspect of any domain an EDO is asked to lead
  - Be accountable and hold others accountable
  - Make cybersecurity part of the programmatic, engineering, and acquisition processes
  - Involve cybersecurity professionals
- Cybersecurity knowledge and leadership is now an essential part of the EDO skillset, no matter where an EDO is assigned
- We need to know how to keep programs focused on cybersecurity and weave it into every aspect of program planning, execution, and maintenance
- Understanding of cyber tools and processes is necessary for acquiring and maintaining secure systems

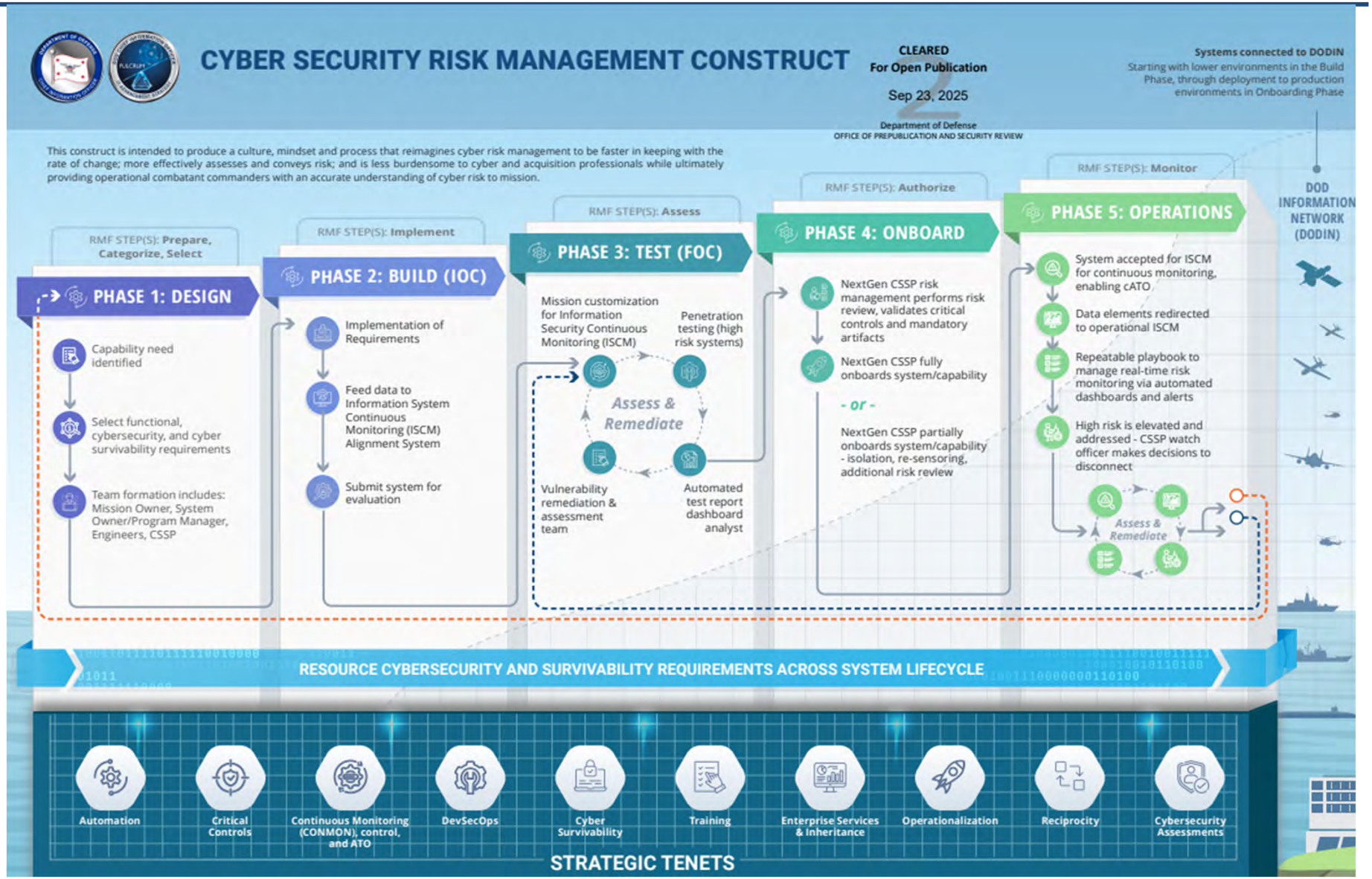
Responsibility for Cybersecurity extends to all members of the acquisition workforce

DoN Implement Zero Trust Blueprint

DON is a Zero Trust aligned organization at all levels by the end of FY2030



Cyber Security Risk Management Construct (CSRMC)



Summary

- Which organization is the Type Commander for cyber?
- Which organization is the Navy's component commander to U.S. Cyber Command
- What process does DoW use to "bake in" cybersecurity in acquisition programs